

Comprehensive Security Architecture & Protocols Specification

A Technical Deep-Dive into Zero-Trust RBAC, Cryptographic SHA-256 Hash Chaining, Dual-Lock Authorization, Field-Level Fernet AES Encryption, Dynamic Watermarking, and Client-Side DLP.

Document Classification: Enterprise Technical Whitepaper

Release Version: 1.0.0-PROD-SEC

Target Audience: SecOps, AppSec, Chief Examiners

Core Architecture: Zero-Trust Defense-in-Depth

1. Executive Summary & Core Security Philosophy

ExamVault is architected around the core engineering principle of **Honesty Over Spectacle**. Standard examination platforms rely on opaque, unverified claims of 'unhackable AI proctoring' or flimsy frontend obfuscation. ExamVault rejects black-box claims and instead implements a mathematically verifiable, multi-layered **Zero-Trust Architecture (ZTA)** with defense-in-depth security controls across the entire examination content lifecycle: from item drafting and moderation to package assembly, dual cryptographic locking, and forensic post-incident attribution.

Core Design Tenets:

- **Zero-Trust Verification:** Never trust, always verify. Every database query, API call, and view event is authenticated, watermarked, and audited.
- **Strict Least-Privilege & Separation of Duties (SoD):** No single administrator or role possesses sufficient cryptographic authority to create, moderate, approve, seal, and export an exam single-handedly.
- **Immutable Cryptographic Auditing:** Forward-linked SHA-256 hash chains guarantee tamper-evident integrity where retroactive modification triggers automated tripwires.
- **Deterministic Evidentiary Attribution:** High-entropy dynamic watermarking and cryptographically permuted option orders isolate leaked screen captures directly to the culprit session.

2. Layered Threat Model & Mitigation Matrix

Threat Vector	Adversary Profile	ExamVault Defense Mechanism	Cryptographic / Enforcement Layer
Database Compromise / Dump	External Hacker / Hostile DBA	Field-Level AES Encryption + Row Level Security (RLS)	Fernet AES-128-CBC + HMAC-SHA256 & pgcrypto AES-256
Audit Log Tampering	Rogue Admin Covering Tracks	Immutable SHA-256 Linear Hash Chaining + Trigger Tripwires	SHA-256 forward hash linking + verify_audit_integrity RPC
Unauthorized Cross-Role Access	Malicious Insider (Setter/Reviewer)	Strict RBAC & DB-level RLS isolation (`auth.uid()`)	PostgreSQL engine-level RLS policies + JWT claims
Rogue Package Release	Compromised Approver Account	Dual-Custody 2-Man Rule (Approver + Admin_2)	Multi-Party Cryptographic Signatures & Manifest Hash
External Phone Screen Photo	Corrupt Candidate / Setter	Dynamic Session Watermark + Deterministic Option Permutation (DOP)	Session Token Steganography + HMAC(Session_ID, Q_ID)
Clipboard Data Scraping	Automated Browser Script / Insider	Client-Side DLP Interception & Context Menu Disabling	JavaScript Event Capture + CSS user-select: none

3. Identity, Multi-Factor Authentication & Device Posture

Authentication in ExamVault operates on a multi-stage zero-trust pipeline designed to eliminate credential theft, session hijacking, and credential-stuffing attacks:

- A. Primary Credential Verification:** User credentials (email + password) are validated against salted bcrypt password hashes stored in PostgreSQL. Standard plaintext passwords are never cached or logged.
- B. Time-Sensitive 2FA OTP Challenge:** Every authentication triggers a 6-digit cryptographic OTP challenge bound to a strict 5-minute expiration timestamp (`expires\_at`).
- C. Biometric Face Liveness Gate:** Users undergo real-time biometric face verification before receiving an active session token. Face verification metadata (`face\_verified`, `verification\_timestamp`) is recorded directly in the session's forensic telemetry.
- D. Device Posture Evaluation:** The system inspects endpoint hardware headers (Device UUID, Browser WebGL Canvas Fingerprint, IP Subnet). Logins from unregistered or unmanaged devices incur an automatic **+35 point risk score penalty**.
- E. Cryptographically Bound Session Tokens:** Successful logins issue short-lived JWT tokens bound to unique `session\_id` UUIDs. Sessions are subject to real-time heartbeat monitoring (every 4 seconds) and auto-suspension upon security lockdown.

4. PostgreSQL Row Level Security (RLS) & Role-Based Access Control

Unlike generic web applications that enforce authorization only at the application routing layer, ExamVault enforces **Row Level Security (RLS) at the PostgreSQL database engine level**. Even if an attacker compromises the frontend or injects API calls, the database kernel strictly refuses queries outside the authenticated user's security boundary.

Role Name	Security Clearance & Boundary	PostgreSQL RLS Enforcement Rule
SETTER	Drafts and edits individual questions. Cannot view other setters' drafts, cannot moderate, cannot assemble final packages.	<code>SELECT/UPDATE WHERE creator_id = auth.uid() AND status IN ('DRAFT', 'NEEDS_REVISION')</code>

REVIEWER	Reviews and moderates assigned question items. Cannot draft new items, cannot create final locked packages.	SELECT/UPDATE WHERE assigned_reviewer_id = auth.uid() AND status = 'UNDER_REVIEW'
APPROVER	Inspects approved questions and constructs exam packages. Applies Lock #1. Cannot sign Lock #2.	SELECT WHERE status = 'APPROVED'; INSERT exam_packages; Cannot self-confirm Lock #2
ADMIN_2	Independent gatekeeper. Validates manifest integrity and applies final Lock #2. Cannot create/modify questions or packages.	UPDATE exam_packages SET status='FINAL_LOCKED' WHERE status='PENDING_DUAL_CONFIRMATION'
INVESTIGATOR	Read-only access to audit ledgers, risk sessions, and leak OCR lab. Zero mutation access to examination questions.	SELECT ON audit_logs, app_sessions, leak_reports; INSERT ON security_events

5. Cryptographic Specifications & Encryption Protocols

ExamVault incorporates defense-in-depth cryptographic primitives across data-in-transit, data-in-use, and data-at-rest:

- A. Data-in-Transit (TLS 1.3):** All communications between client endpoints, FastAPI backend, and Supabase PostgreSQL utilize TLS 1.3 with Perfect Forward Secrecy (ECDHE-ECDSA-AES256-GCM-SHA384). Legacy SSL/TLS 1.0/1.1 are disabled.
- B. Field-Level Symmetric Fernet Encryption:** Sensitive columns (question_text, correct_answer, explanation) are encrypted prior to database insertion using Fernet authenticated symmetric encryption. Fernet guarantees: (1) 128-bit AES in CBC mode with PKCS7 padding; (2) HMAC-SHA256 message authentication code; (3) 128-bit initialization vector (IV); (4) 64-bit timestamp validation.
- C. Database Storage Volume Encryption:** PostgreSQL volume data and write-ahead logs (WAL) are encrypted at rest using AES-256 XTS encryption.
- D. Web Crypto API In-Browser Verification:** The frontend utilizes native Web Crypto API (crypto.subtle.digest('SHA-256')) for hardware-accelerated client-side integrity validation.

6. Immutable SHA-256 Hash-Chained Audit Ledger

To prevent rogue administrators or database intruders from covering their tracks, ExamVault implements a linear cryptographic ledger inspired by blockchain block-hashing. Every security event forms an unbroken mathematical chain:

```
Current_Log_Hash = SHA256( Event_ID || User_ID || Action || Resource_ID || Canonical_Metadata || Previous_Log_Hash )
```

Mathematical Guarantees:

- 1. Pre-image & Collision Resistance:** Because SHA-256 is cryptographically one-way, it is computationally infeasible (2^{256} operations) to alter past metadata without producing an entirely different hash.
- 2. Cascade Invalidation:** Modifying even a single character in Event #4 automatically invalidates the stored hashes of Events #5, #6, ..., #N.
- 3. Automated Tripwire RPC:** The PostgreSQL procedure verify_audit_integrity() recalculates the forward hash chain from Genesis to tip. If any mismatch is detected, the database immediately flags an INTEGRITY_ALERT, locks non-investigator access, and alerts the Security Operations Center.

7. Dual-Lock Cryptographic Custody (2-Man Rule)

In high-stakes examinations (e.g., UPSC, JEE, Medical Boards), single-party approval is a critical security vulnerability. ExamVault enforces a multi-party cryptographic authorization gate for package generation:

- **Step 1 — Package Assembly & Lock #1:** Approver_1 verifies questions, defines the exam manifest, and signs Lock #1. The package enters state PENDING_DUAL_CONFIRMATION.
- **Step 2 — Independent Audit & Lock #2:** Admin_2 (operating from an isolated clearance terminal) inspects the package contents, verifies question distribution, and applies Lock #2.
- **Manifest Package Hash:** The master SHA-256 certificate is computed across all verified question hashes: `Package_Hash = SHA256( Q1_Hash || Q2_Hash || ... || Approver1_Signature || Admin2_Signature || Timestamp )`.
- **Rejection & Return Protocol:** If Admin_2 identifies anomalies, the package is rejected with formal reasons logged to the audit ledger and returned to the authoring pipeline.

8. Dynamic Forensic Watermarking & Content Fingerprinting

ExamVault incorporates active forensic defense mechanisms against unauthorized physical screen photography and insider leaking:

- A. Dynamic Canvas Micro-Watermarking:** Every viewing session renders low-opacity, high-entropy forensic watermarks directly onto the UI canvas. Watermark tokens encode: `User_ID • Session_UUID • Device_ID • Timestamp • IP_Hash`. Even if a smartphone captures the physical screen, the watermark identifies the viewing session.
- B. Deterministic Option Permutation (DOP):** Multiple-choice question options (A, B, C, D) are deterministically shuffled per session using a cryptographic seed: `Seed = HMAC_SHA256(Session_ID, Question_ID)`. The answer key is dynamically re-mapped in memory. If a leaker shares option letters (e.g., 'Q1 is B, Q2 is D'), the sequence is mathematically unique to their session.
- C. Forensic Leak Investigation Lab:** Investigators upload suspected leak photos into the FastAPI OCR engine. Tesseract OCR + OpenCV image enhancement extracts watermarks, parses text fragments, and correlates the leak against historical session logs to generate formal evidentiary reports.

9. Explainable Risk Engine & Automated Lockdown Protocols

ExamVault rejects opaque 'AI black-box' claims in favor of a deterministic, point-based behavioral risk scoring engine:

Risk Signal	Score Penalty	Detection Logic & Security Rationale
Unregistered Device	+35 pts	Device posture mismatch; client fingerprint not found in corporate registry.
Outside-Hours Access	+25 pts	Activity detected outside authorized operational time window (22:00 - 06:00).
High Velocity Views	+30 pts	Rapid sequential item requests exceeding human reading velocity (>15 items/min).
IP Subnet Shift	+40 pts	Geographic or ISP subnet change mid-session indicating proxy or token theft.
Failed 2FA Retries	+20 pts	Repeated incorrect OTP challenges indicating brute-force attempt.

Threat Level Response Thresholds:

- **NORMAL (Score 0–39):** Full access within authorized workspace boundary.
- **ELEVATED (Score 40–69):** Step-up biometric challenge triggered; real-time telemetry flagged in Investigator console.
- **HIGH RISK / SUSPENDED (Score 70–100):** Automated session termination. Active token revoked, database status set to SUSPENDED, and investigator triage required.
- **SYSTEM LOCKDOWN:** Emergency broadcast via Supabase WebSockets. Restricts all non-investigator access across the entire platform instantly.

10. Client-Side Sandbox & Data Loss Prevention (DLP)

To prevent casual or automated text scraping at the browser client level, ExamVault integrates active DLP controls:

- **Text Selection Blocking:** Applied CSS user-select: none across all question cards and package tables.
- **Clipboard Interception:** Intercepts copy, cut, and selectall events globally in protected workspaces. Displays real-time security alerts upon violation.
- **Context Menu Suppression:** Disables right-click context menus over sensitive examination content.
- **Active Workspace Isolation:** Workspace navigation bars, sidebars, and routes strictly isolate access to authorized profiles.

EXAMVAULT ARCHITECTURAL COMPLIANCE STATEMENT

This specification certifies that ExamVault v1.0 meets and enforces the security requirements for high-stakes examination protection: Zero-Trust Least Privilege, PostgreSQL Engine RLS, Field-Level Fernet AES Encryption, Cryptographic SHA-256 Hash Chained Auditing, 2-Man Dual-Lock Custody, and Dynamic Session Watermarking. Plaintext sensitive content is never stored raw, and every administrative action produces an immutable mathematical audit record.